HAICHAIN

संस्थागत जोखिम देय परिश्रम रिपोर्ट V1.1 • क्रिप्टोग्राफिक रक्षा मानक

HAICHAIN: संस्थागत जोखिम देय परिश्रम और सुरक्षा ऑडिट रिपोर्ट

टियर-1 उद्यम पूंजीपतियों और शीर्ष ऑडिट फर्मों के लिए गणितीय प्रमाण और रेड-टीम सत्यापन मैट्रिक्स

लक्षित दर्शक
टियर-1 उद्यम पूंजी और ऑडिट फर्म

क्रिप्टोग्राफिक सुरक्षा
हार्डवेयर पासकी • 9 अपरिवर्तनीय नियम

प्रोटोकॉल कर्नेल
HAICHAIN v1.1 • CapLeaf 223 बाइट्स

HAICHAIN संस्थागत जोखिम देय परिश्रम और सुरक्षा ऑडिट रिपोर्ट

गणितीय प्रमाण, खतरा मॉडलिंग और रेड-टीम सुरक्षा सत्यापन मैट्रिक्स

लक्ष्य दर्शक: टियर-1 वेंचर कैपिटलिस्ट (a16z crypto, Paradigm, Sequoia), संस्थागत कस्टोडियन और शीर्ष ऑडिट फर्म (OtterSec, Neodyme, Kudelski Security)
प्रोटोकॉल संस्करण: HAICHAIN Kernel v1.1 / CapLeaf v1 (223 बाइट्स वायर स्कीमा)
मानक: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. कार्यकारी सारांश और सुरक्षा प्रतिमान

वित्तीय माइक्रो-भुगतान निष्पादित करने वाले स्वायत्त एआई एजेंट मानव-संचालित डेफी से मौलिक रूप से भिन्न हमले की सतह पेश करते हैं: 1. **शून्य मानवीय हस्तक्षेप विलंबता:** उपकरण कॉल निष्पादित करने वाले एआई एजेंट को अप्रत्यक्ष प्रॉम्प्ट इंजेक्शन (Indirect Prompt Injection) के माध्यम से सेकंडों में हजारों अनधिकृत भुगतान वाउचर जारी करने के लिए मजबूर किया जा सकता है। 2. **निजी कुंजी रिसाव भेद्यता:** वितरित नोड्स पर एजेंट चलाने से निजी कुंजी रिसाव का जोखिम बढ़ जाता है। 3. **सिबिल फर्जी व्यापारियों का प्रसार:** खुले नेटवर्क में, दुर्भावनापूर्ण व्यापारी दर सीमाओं को दरकिनार करने के लिए असीमित अस्थायी डोमेन पंजीकृत कर सकते हैं।

मिलीसेकंड गति का त्याग किए बिना इस समस्या को हल करने के लिए, **HAICHAIN निष्पादन को फंड कस्टडी से पूरी तरह अलग करता है**: - **सर्वोच्च संप्रभु नियंत्रण:** WebAuthn FIDO2 हार्डवेयर बायोमेट्रिक पासकी (P-256) ट्रेजरी पर 100% पूर्ण स्वामित्व बरकरार रखती है। - **सब-एजेंट अनुमतियों का अलगाव:** क्षणिक Ed25519 कुंजियाँ नीति इंजन (Policy Engine) में सैंडबॉक्स की गई हैं, जिनकी वॉलेट सीड वाक्यांश तक कोई पहुंच नहीं है। - **ऑन-चेन मर्कल एंकर:** 223-बाइट स्कीमा सोलाना L1 पर 9 गणितीय अपरिवर्तनीय नियमों (I_1 ... I_9) को सख्ती से लागू करती है।

2. औपचारिक खतरा मॉडल और हानि सीमा (T_4)

एजेंट की निजी कुंजी से समझौता होने और मर्कल ट्री में व्यापारी के साथ मिलीभगत के सबसे खराब परिदृश्य में भी, अधिकतम चोरी $E_{theft}(\tau)$ गणितीय रूप से सख्ती से सीमित है:

$$E_{theft}(\tau) \le \min(B, \quad K, \quad W_p \cdot n(\tau, \omega_p), \quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

व्यावहारिक परिणाम: 10,000 USDT बैलेंस वाले संस्थागत फंड के लिए, 50 USDT लीफ बजट और 10 USDT / घंटा वेग सीमा के साथ, हमलावर फ्रीज लागू होने से पहले 10 **USDT से अधिक नहीं चुरा सकता**, जिससे फंड की 9,990 **USDT (99.9%)** संपत्ति सुरक्षित रहती है।

3. 5-सूत्रीय रेड-टीम सुदृढ़ीकरण और 9 अपरिवर्तनीय नियम

1. **एस्क्रो दोहरा दावा रोकथाम:** $P_i \le \min(C_i, R_i)$ के तहत अपरिवर्तनीय निपटान।
2. **कैनोनिकल ATA खाता सुरक्षा:** तीसरे पक्ष के खातों में रीडायरेक्शन पर पूर्ण रोक।
3. **पैनिक फ्रीज अलगाव (I_6):** आपातकालीन फ्रीज के बाद पुराने वाउचर तुरंत अमान्य।
4. **किराया लैम्पॉर्ट्स वापसी:** सभी अप्रयुक्त लैम्पॉर्ट्स मूल फंड में वापस।
5. **सिबिल बजट सीमा:** पैरेंट टेम्पलेट सीमा से अधिक निकासी संभव नहीं।

9 गणितीय नियम (I_1 ... I_9) पूंजी संरक्षण और सुरक्षा की गारंटी देते हैं।

4. 9 गणितीय अपरिवर्तनीयता ऑन-चेन ऑडिट रिपोर्ट ($I_1 \dots I_9$)

`programs/haichain-core/src/lib.rs` में प्रत्येक ऑन-चेन निर्देश बिना किसी अपवाद के सभी 9 स्थिति अपरिवर्तनीयों को सुरक्षित रखता है:

1. I_1 (पूंजी संरक्षण सिद्धांत):

$$\text{Vault}_{\text{ATA}} + \sum_{\text{channels}} \text{Escrow}_j + \sum \text{Paid}_j + \text{Refunds} = \text{शुद्ध जमा}$$

परीक्षण सूट में `test_invariant_i1_conservation` द्वारा सत्यापित।

2. I_2 (विहित प्राप्तकर्ता सुरक्षा):

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

Anchor बाधा के माध्यम से ऑन-चेन लागू: टोकन खाते के अनधिकृत पुनर्निर्देशन को रोकता है।

3. I_3 (अपरिवर्तनीय बजट सीमा):

$$\text{consumed} \le \texttt{max_spend} \quad \wedge \quad \texttt{budget_used} \le \texttt{budget_total}$$

प्रत्येक रिजर्व या निपटान निष्पादन से पहले अनिवार्य रूप से जांचा गया।

4. I_4 (स्वायत्त वेग दर सीमक):

$$\texttt{window_used} \le \texttt{window_cap} \qquad \forall\, t \in [T_0, T_0 + \omega]$$

तीव्र स्वचालित पूंजी निकासी को रोकता है।

5. I_5 (एकदिष्ट PDA संकीर्णन):

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

उप-उदाहरण कभी भी मूल द्वारा दी गई अनुमतियों को विस्तृत नहीं कर सकते।

6. I_6 (पैनिक युग और तत्काल फ्रीज अलगाव):

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg\, \texttt{pot.frozen}$$

तत्काल प्रोटोकॉल फ्रीज सभी संचलन में मौजूद वाउचर को तुरंत रद्द कर देता है।

7. I_7 (सत्र समाप्ति नियंत्रण):

$$\texttt{current_time} \le \texttt{valid_until}$$

समाप्त या परित्यक्त सत्र नए रिजर्व निष्पादित नहीं कर सकते।

8. I_8 (एकदिष्ट निपटान और एक बार का दावा):

$$\text{paid}_{\text{new}} \leq \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{\text{new}} \geq \text{paid}_{\text{old}}$$

वाउचर में डबल-स्पेंडिंग और रीप्ले हमलों को पूरी तरह समाप्त करता है।

9. I_9 (सिबिल खाता अलगाव):

$$\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id}) \text{ अद्वितीय है}$$

एक क्षमता लीफ ठीक एक ऑन-चेन खाते से विशिष्ट रूप से मैप होती है।
